

Introduction à Burp Suite

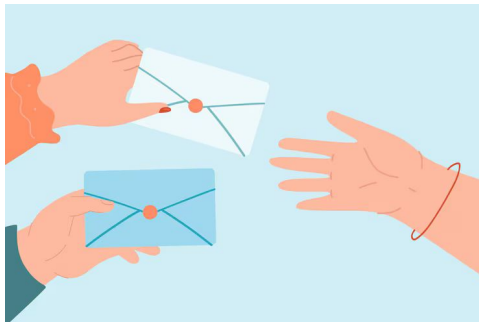
Outil pour les audits de sécurité web, développé par PortSwigger



Proxy (desktop & mobile)

Intercepte toutes les requêtes HTTP envoyées et reçues par le navigateur

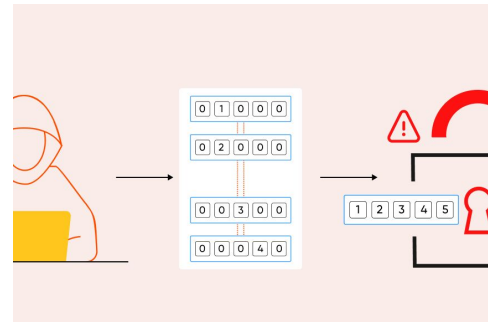
→ comprendre le trafic et le modifier



Repeater

Rejouer des requêtes HTTP et les modifier à volonté

→ exploiter des vulnérabilités en modifiant les paramètres de la requête



Intruder

Envoi automatique de requêtes HTTP en masse

→ bruteforcer des paramètres (code PIN, IDOR, ...)

Burp Suite

Créer un projet
temporaire



Burp Suite Community Edition v2025.7.4

Welcome to Burp Suite Community Edition. Use the options below to create or open a project.

Note: Disk-based projects are only supported on Burp Suite Professional.

☒ **Temporary project in memory**

☐ **New project on disk**

Name:

File:

☐ **Open existing project**

Name	File	Last Accessed
------	------	---------------

File:

☒ Trust this project file

☒ Pause Automated Tasks



Installer l'extension
"JWT Editor"

Burp Suite Community Edition v2025.7.4 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer

Extensions Learn

Install BApp Store APIs BChecks Bambda library Extensions settings

Filter JWT

Name	Author	Rating	Popularity
JWT Editor	Dolph Flynn, Fraser Winterborn	★★★★★	
JSON Web Tokens	Oussama Zgheb	★★★★★	
JWT Scanner	Dario Caluzi, Cyrill ...	★★★★★	
Add Custom Head...	Lorenzo Grespan	★★★★★	
SignSaboteur, We...	Zakhar Fedotkin, P...	★★★★★	
EsPRESSO	Tim Guenther, Chri...	★★★★★	
Token Tailor	forteBruno	★★★★★	
Session Handler+	Vinaya Kumar	★★★★★	
DPoP Authenticator	Serhat Cicek	★★★★★	

JWT Editor
Dolph Flynn, Fraser Winterborn

Submit Reinstall

Rating: ★★★★★ Popularity: Version: 2.6 Updated: 30 Apr 2025

JWT Editor is a comprehensive tool for analyzing and manipulating JSON Web Tokens (JWTs) within Burp. It provides rich editing capabilities for both JSON Web Signatures (JWS) and JSON Web Encryptions (JWE), as well facilitating some of the common attacks on JWS implementations and their use within Burp.

Features

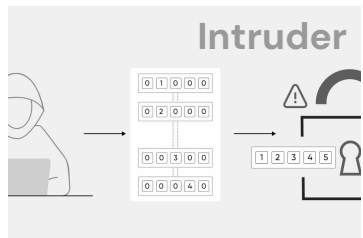
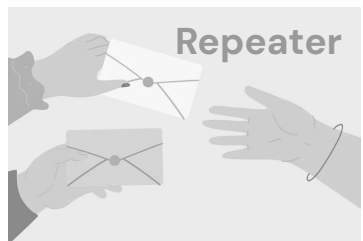
- Top-level *JWT Editor* tab for managing cryptographic keys, persistent storage of tokens and extension configuration.
- Custom *JSON Web Token* tab within HTTP and WebSocket message editors for viewing and modifying JWTs.
- Automatic JWT detection and highlighting in HTTP and WebSocket Proxy History.
- Support for signing, verifying, encrypting and decrypting JWTs using stored keys.
- Support for a range of common attacks on JWS.
- Intruder payload provider for fuzzing within JWS.
- Scanner insertion point provider to allow Burp's Scanner to insert payloads within JWS headers.

Usage

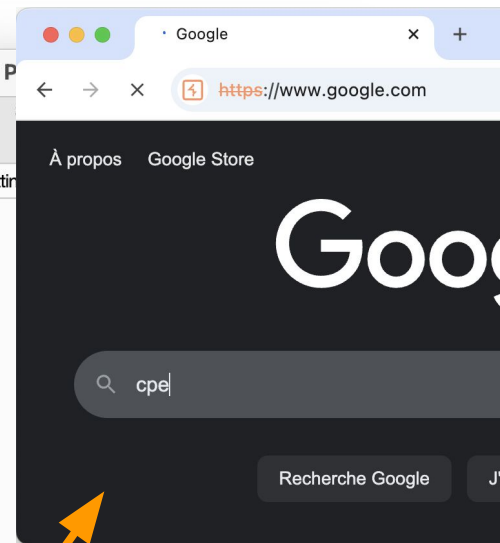
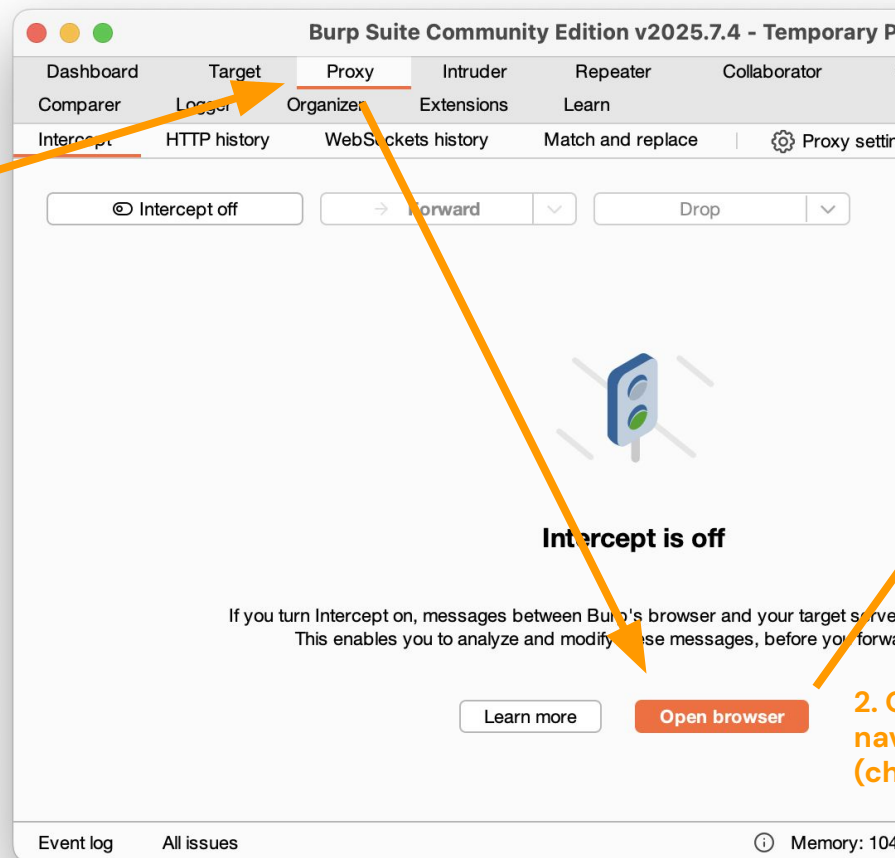
The *JWT Editor* tab allows you to manage keys, store interesting tokens and configure the extension. Configured keys are then available for use throughout the extension.

Event log (1) All issues Memory: 193.2MB Disabled

Burp Suite



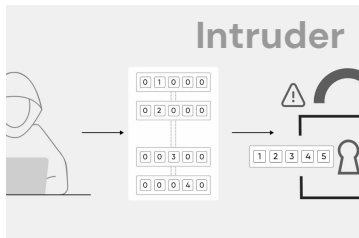
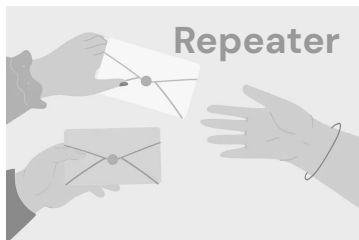
1. Onglet Proxy



3. Naviguer sur le site à tester

2. Ouvrir le navigateur Burp (chromium)

Burp Suite



4. Onglet HTTP history

Burp Suite Community Edition v2025.7.4 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder
Comparer Logger Organizer Extensions Learn

Intercept HTTP history WebSockets history Match and replace Proxy settings

Filter settings: Hiding CSS, image and general binary content

5. Inspecter la liste des requêtes interceptées

#	Host	Method	URL
166	https://www.google.com	GET	/xjs/_/js/m...s.fr.C3JH77hC-Tl.2018.O/ck=xjs.s.j9XrSaSngvM.L.B1.O/am=ACEAAIBAC
165	https://www.google.com	GET	/complete/search?q=cpe&cp=0&client=desktop-gws-wiz-on-focus-serp&xssi=t&gs_pcr
164	https://www.google.com	GET	/complete/search?q=cpe&cp=0&client=gws-wiz-serp&xssi=t&gs_pcr=2&hl=fr&authuser=0&p
163	https://www.google.com	POST	/...

6. Détails d'une requête

Request Response

Pretty Raw Hex

```
1 GET /complete/search?q=cpe&cp=0&client=desktop-gws-wiz-on-focus-serp&xssi=t&gs_pcr=3&hl=fr&authuser=0&pq=cpe&psi=_1zAaM75IqWxkdUP3_ecoAU.1757437184145&dpr=2&ofp=EAEYudHu-e6m4aFaGMvmkdzo45KHexj4mY3u3u69LPUBGNa5uMZNho-tIRjB8JeMuonktccBMokBCgoKCGNwZSBsew9uG8KDWnWZSBmb3JtYXRpb24KQ0oLY3BliHNhbGFpcmlKEwoRY3BliHNpZ25pZmVjYXRpb24KQ0oLY3BliGNhcnRlChMKEWNwZSBtYW5pZmVzdGF0aW9uGg4KDGNgWZSBjb25jb3VycwoSchBjcGUgaW5mb3JtYXRpcXVlEEcybgogCh5RdWVsIGRpcGZDtG1lIHBvdXIgw6p0cmUgQ1BFID8KHwodUXVlbCB1c3QgbGUgc00bGUgZCd1bmUgQ1BFID8KJgokUXVlbCB1c3QgbGUgc2FsYWlyZSBtb3llbiBkZ3VuIENQRSA_EOQC HTTP/2
2 Host: www.google.com
```

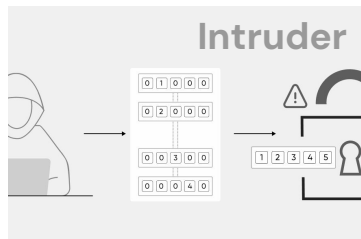
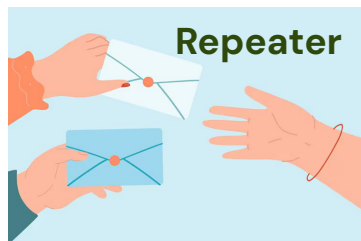
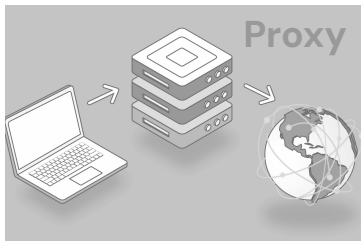
Inspector

- Request attributes: 2
- Request query parameters: 11
- Request cookies: 4
- Request headers: 32
- Response headers: 28

Event log All issues

Memory: 160.4MB Disabled

Burp Suite



Burp Suite Community Edition v2025.7.4 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder

Comparer Logger Organizer Extensions Learn

Intercept HTTP history WebSockets history Match and replace Proxy settings

Filter settings: Hiding CSS, image and general binary content

#	Host	Metho	URL
165	https://www.google.com	GET	/xjs/_/_js/md=2/k=xjs.s.fr.C3JH77hC-TI.2018.O/am=AAAAAAAAAAAAAAAAAAAAAA
166	https://www.google.com	GET	/xjs/_/_js/k=xjs.s.fr.C3JH77hC-TI.2018.O/ck=xjs.s.j9XrSaSngvM.LB1.O/am=ACEAAIBAC
165	https://www.google.com	GET	/complete/search?q=cpe&cp=0&client=desktop-gws-wiz-on-focus-serp&xssi=t&gs_per

Request **Response**

Pretty Raw Hex

1 GET /complete/search?q=cpe&cp=0&client=desktop-gws-wiz-on-focus-serp&xssi=t&gs_pcert=3&hl=fr&authuser=0&pq=cpe&psi=_1zAaM7SIqWxkdUP3_ecoAU.1757437184145&dpr=2&ofp=EAeyudHu-e6m4aFaGMvmkdzo45KHexj4mY3u3u69LPUBGNa5uMzNho-tIRjB8JeMuonktccBMokBCgoKCGNwZSBseW9uCg8KDNwZSBmB3JtYXRpb24KDQoLY3B1IHhnbGFpcUKEwoRY3B1IHNP225pZmljYXRpb24KCwoJY3B1IGNhcnRlChMKEWwZSBtYW5pZmVzdGF0aW9uCG4KDGwZSBjb25jb3VycwoSchBjcGUgaW5mb3JtYXRpcXVLEecybgogCh5RdWVsIGRpcGZDtG1lIHbvdXIgw6p0cmUgQ1BFID8KHwodUXVlbCB1c3QgbGUgc00bGUGZCd1bmUgQ1BFID8KJgokUXVlbCB1c3QgbGUgc2FsYWlyZSBtb3llbiBkJ3VuIENQRSA_EOQC HTTP/2

2 Host: www.google.com

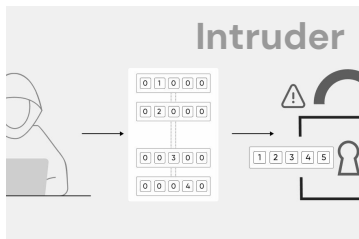
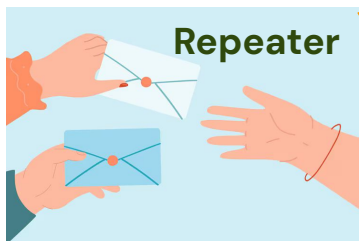
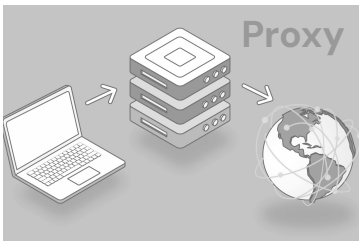
Event log All issues

0 highlights

https://www.google.com/compl...yZSBtb3llbiBkJ3VuIENQRSA_EOQC

- Add to scope
- Scan
- Send to Intruder
- Send to Repeater
- Send to Sequencer
- Send to Organizer
- Send to Comparer (request)
- Send to Comparer (response)
- Show response in browser
- Request in browser
- Engagement tools [Pro version only]
- Show new history window
- Add notes
- Highlight
- Delete item
- Close history

Burp Suite



1. Onglet Repeater

Burp Suite Community Edition v2025.7.4 - Temporary Project

Dashboard Target Proxy Intruder **Repeater** Collaborator Sequencer Decoder Comparer Logger

Organizer Extensions Learn

1 x **3. Envoyer** **2. Modifier la requête**

Send Cancel < >

Target: <https://www.google.com> HTTP/2

Request

Pretty Raw

```
GET /complete/search?q=test&cp=0&client=desktop-gws-wiz-on-focus-serp&xssi=t&gs_pcrt=3&hl=fr&authuser=0&pq=cpe&psi=_1zAaM7SIqWxkdUP3_ecoAU.1757437184145&dpr=2&ofp=EAEYudHu-e6m4aFaGMvmkdzo45KHExj4mY3u3u69lPUBGNa5uMzNho-tIRjB8JJeMuonktccBMokBCGoKCGNwZSBseW9uCG8KDNwZSBmb3JtYXRpb24KDQoLY3BlIHNhbGFpcmkUEwoRY3BlIHNPz25pZmJtYXRpb24KcwoJY3BlIGNhcnRlChMKEWwZSBtYW5pZmVzdGF0aW9uCG4KDGNwZSBjb25jb3VycwoSChBjcGUgaw5mb3JtYXRpcXVlEEcybgogCh5RdWVsIGRpcGZDtG1lIHbvdXIgw6p0cmUgQ1BFID8KHwodUXVlbCBlc3QgbGUgc00bGUGZCd1bmUgQ1BFID8KJgokUXVlbCBlc3QgbGUgc2FsY
```

Response

Pretty Raw Hex

```
1 HTTP/2 200 OK
2 X-Content-Type-Options: nosniff
3 Date: Tue, 09 Sep 2025 17:05:48 GMT
4 Pragma: no-cache
5 Expires: -1
6 Cache-Control: no-cache, must-revalidate
7 Content-Type: application/json; charset=UTF-8
8 Strict-Transport-Security: max-age=31536000
9 Content-Security-Policy: object-src 'none';base-uri 'self';script-src 'nonce-0MVPBPuQZYF-kkHRB0E1gQ' 'strict-dynamic' 'report-sample' 'unsafe-eval' 'unsafe-inline' https: http:;report-uri
```

Inspector

Selection 4 (0x4)

Selected text

test

Decoded from: URL encoding

test

Cancel Apply changes

Request attributes 2

Request query parameters 11

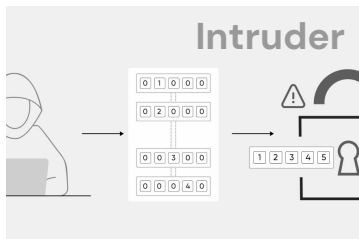
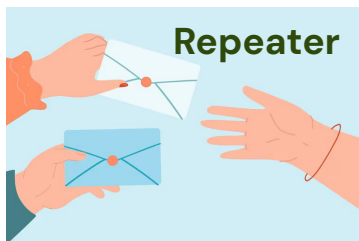
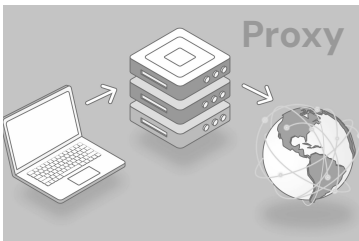
Request body parameters 0

Request cookies 4

Done 1,903 bytes | 76 millis

Event log All issues Memory: 166.5MB Disabled

Burp Suite



Burp Suite Community Edition v2025.7.4 - Temporary Project

Dashboard Target Proxy Intruder **Repeater** Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn JWT Editor

1 2 x +

Send Cancel < >

4. Voir et modifier le JWT

5. Renvoyer

Target: https://7ca29fafd72c4f29.dashbox.cloud HTTP/2

Request

Pretty Raw Hex JSON Web Token

JWT 1 - eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VybmFtZSI6Im1hcmMILCJp...

Serialized JWT

```
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VybmFtZSI6Im1hcmMILCJp...Qj0jE3NTc0Mzc3MTN9.5C5EUIWvaB8oZVm1cNRtKgtKMAzVd0RxeKEKXJaKN4
```

Copy Decrypt Verify

JWS JWE

Header

```
{  "alg": "HS256",  "typ": "JWT"}
```

Format JSON Compact JSON

Payload

```
{  "username": "marc",  "iat": 1757437713}
```

Format JSON Compact JSON

Signature

```
E4 2E 44 50 85 AF 68 1F 28 65 59 A5 D5 A8 2D 28 C0 37 CD 57 74 47 19 04 29 72
```

Attack Sign Encrypt

Information

- Issued At - Tue Sep 09 2025 19:08:33 GMT+2

Send to Tokens

Response

Inspector

Request attributes 2

Request query parameters 0

Request body parameters 0

Request cookies 1

Name	Value
jwt-v1	eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VybmFtZSI6Im1hcmMILCJp...Qj0jE3NTc0Mzc3MTN9.5C5EUIWvaB8oZVm1cNRtKgtKMAzVd0RxeKEKXJaKN4

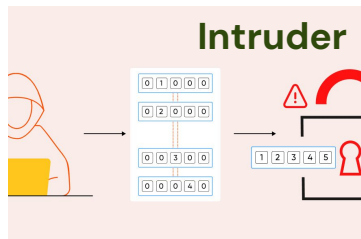
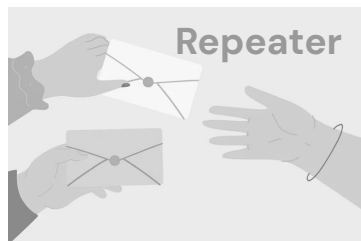
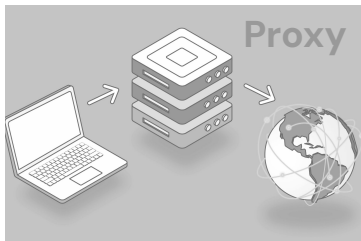
Request headers 18

Voir où se trouve le JWT

Event log (1) All issues

Memory: 181.6MB Disabled

Burp Suite



Burp Suite Community Edition v2025.7.4 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger

Organizer Extensions Learn JWT Editor

1 2 x +

Send Cancel < >

Target: <https://7ca29afd72c4f29.dashbox.cloud> HTTP/2

Request

Pretty Raw Hex

```
1 GET /info HTTP/2
2 Host: 7ca29afd72c4f29.
3 Cookie: jwt-v1=
  eyJhbGciOiJIUzI1NiIsInR
  FkbWluIiwiaWF0IjoxNzU3N
  gtKMA3zVd0RxxkEKXJaKN4
4 Sec-Ch-Ua-Platform: "ma
5 Accept-Language: fr-FR,
6 Sec-Ch-Ua: "Chromium";v
7 Content-Type: applicati
8 Sec-Ch-Ua-Mobile: ?0
9 User-Agent: Mozilla/5.0
  10_15_7) AppleWebKit/53
  Chrome/139.0.0.0 Safari
10 Accept: */*
11 Sec-Fetch-Site: same-or
12 Sec-Fetch-Mode: cors
13 Sec-Fetch-Dest: empty
14 Referer: https://7ca29f
15 Accept-Encoding: gzip,
16 Priority: u=1, i
17
```

Response

Inspector

Request attributes 2

Request query parameters 0

Request body parameters 0

Request cookies 1

Name	Value
jwt-v1	eyJhbGciOiJIUzI1NiIsInR...

Request headers 18

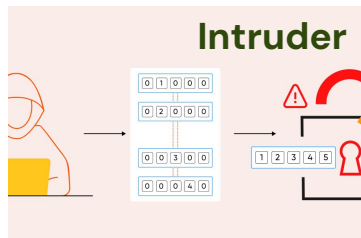
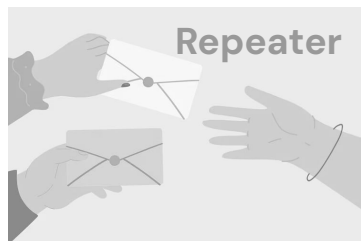
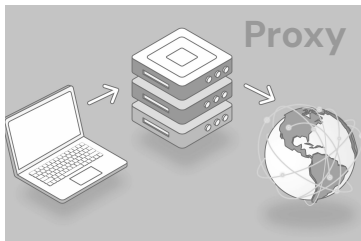
Event log (1) All issues

Memory: 185.2MB Disabled

Context Menu:

- Scan
- Send to Intruder
- Send to Repeater
- Send to Sequencer
- Send to Comparer
- Send to Decoder
- Send to Organizer
- Insert Collaborator payload
- Request in browser
- Engagement tools [Pro version only]
- Change request method
- Change body encoding
- Copy
- Copy URL
- Copy as curl command (bash)
- Copy to file
- Paste from file
- Save item
- Save entire history
- Paste host / URL as request
- Add to site map
- Convert selection

Burp Suite



1. Onglet Intruder

2. Choisir le paramètre à remplacer

5. Lancer l'attaque

3. Choisir le type de paramètre

4. Remplace \$\$ par des nombres de 1 à 100

Burp Suite Community Edition v2025.7.4 - Temporary Project

Dashboard Target Proxy **Intruder** Repeater Collaborator Sequencer Decoder Comparer Logger

Organizer Extensions Learn **JWT Editor**

1 2 x +

Sniper attack Start attack

Target ishbox.cloud ☒ Update Host header to match target

Positions And \$ Clear \$ Auto \$

```
1 GET /info/$$ HTTP/2
2 Host: ca29fafd72c4f29.dashbox.cloud
3 Cookie: jwt-v1=eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VybmF1dXN0Ij0iIiwiaWF0IjoxNzU3NDM3ZDZlQy5CSEUwVWVhB8oZVml1cNRTKgtKMA3zVd0RxxEKXJaKN4
4 Sec-Ch-Ua-Platform: "macOS"
5 Accept-Language: fr-FR, fr;q=0.9
6 Sec-Ch-Ua: "Chromium";v="139", "Not;A=Brand";v="99"
7 Content-Type: application/json
8 Sec-Ch-Ua-Mobile: ?0
9 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/139.0.0.0 Safari/537.36
10 Accept: */*
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: cors
13 Sec-Fetch-Dest: empty
14 Referer: https://7ca29fafd72c4f29.dashbox.cloud/
```

Event log (1) All issues 1 highlight 1 payload position Length: 700

Memory: 185.2MB Disabled

Payloads

Payload position: All payload positions

Payload type: Numbers

Payload count: 100

Request count: 100

Payload configuration

This payload type generates numeric payloads within a given range and in a specified format.

Number range

Type: ☒ Sequential ☐ Random

From: 1

To: 100

Step: 1

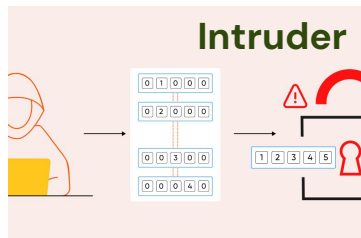
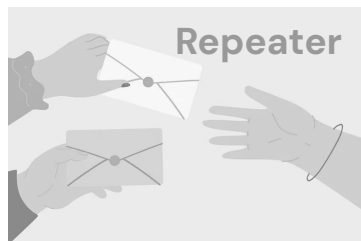
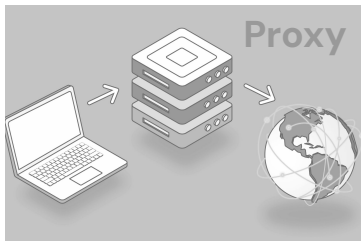
How many:

Number format

Base: ☒ Decimal ☐ Hex

Min integer digits: 0

Burp Suite



2. Intruder attack of https://7ca29f72c4f29.dashbox.cloud

Attack ▾ Save ▾ || ?

2. Intruder attack of https://7ca29f72c4f29.dashbox.cloud

Results Positions

Capture filter: Capturing all items Apply capture filter

View filter: Showing all items

Request	Payload	Status code	Response ...	Error	Timeout	Length	Comment
0		200	21			263	
1	1	404	18			368	
2	2	404	18			368	
3	3	404	18			368	
4	4	404	22			368	
5	5	404	22			368	
6	6	404	19			368	
7	7	404	21			368	
8	8	404	17			368	
9	9	404	21			368	

Request Response

Pretty Raw Hex Render

```
1 HTTP/2 404 Not Found
2 Content-Security-Policy: default-src 'none'
3 Content-Type: text/html; charset=utf-8
4 Date: Tue, 09 Sep 2025 17:27:08 GMT
5 X-Content-Type-Options: nosniff
6 X-Powered-By: Express
7 Content-Length: 145
8
9 <!DOCTYPE html>
10 <html lang="en">
```

27 of 100

0 highlights

Arrêter

Liste des paramètres testés

Réponses associées (code HTTP, taille, ...)

Clic sur une ligne, visualisation de la réponse

Progression